
Joint SOC 2 + PCI DSS

Programme playbook for NBFCs running both
Dedup logic, joint calendar, shared evidence,
NBFC lessons learned, and a single dashboard view.

What this playbook will deliver:

- Decide JOINT vs DISTINCT vs STANDALONE for every control
- Run an 18-month programme where SOC 2 and PCI ROC overlap without conflict
- Reduce duplicate engineering hours by ~30% via shared evidence
- Schedule audits in the right order so each informs the other
- Survive the joint audit day when both teams are in your office in the same month
- Quantify the savings in FTE-hours and audit fees
- Defend NBFC-specific scoping to either set of auditors

Edition v1.0 | July 2026

Companion documents: SOC2_for_NBFC_Playbook.pdf (47 pages) and

PCI_DSS_v4_for_NBFC_Playbook.pdf (45 pages) in adjacent folders. This playbook assumes you've read them; it orchestrates both of them into one programme.

Table of Contents

<i>What this playbook will deliver:</i>	1
Why your NBFC should run SOC 2 + PCI DSS as one programme	4
Chapter 1. Three independent pressures hit the same NBFC CISO	4
Chapter 2. Five ratios from real NBFCs that justify dedup	4
Chapter 3. When joint DOES NOT make sense	4
How the crosswalk is decided	5
Chapter 4. The 4 tags (and 1 workaround)	5
Chapter 5. Six rules for tagging decisions	5
Chapter 6. The dedup workflow (how to actually run it)	5
How to schedule two audits so that each informs the other	7
Chapter 7. Four reference calendars - pick by annual business cycle	7
Chapter 8. Phase Plan - 18 months (joint)	7
How to organise one repository that satisfies two standards	8
Chapter 9. The single evidence repository pattern	8
Chapter 10. The evidence index file (YAML on each evidence)	8
Chapter 11. Cross-tagged workflows that win auditors	8
What works and what doesn't when an Indian NBFC runs both	10
Chapter 12. Six recurring traps NBFC joint programmes fall into	10
Chapter 13. NBFC cross-cutting controls (one warrior, six fronts)	10
A unified documentation checklist that satisfies both standards	11
Chapter 14. The 60-document joint register	11
Chapter 15. Cross-accountability map	11
What partners/auditors will ask about joint-programme NBFC	12
Q1. Are SOC 2 + PCI DSS run by the same team?	13
Q2. How do you decide joint vs separate?	14
Q3. How is cost saving quantified?	15
Q4. What about RBI 2h timer in joint IR?	16
Q5. Co-lending bank data — in scope for SOC 2?	17
Q6. What if SOC 2 ROC and PCI ROC arrive in same month?	18
Q7. How does Vanta / Drata fit joint?	19
Q8. How is ASV vendor chosen for joint scenario?	20
Q9. Trajectory over next 3 years?	21

Q10. Why dual Big 4 not single?	22
Q11. NBFC: how do you handle DPDP's 72-hour breach notification alongside PCI? . . .	23
Q12. RBI Tokenisation - impact on joint scope?	24
Q13. Cross-accountability how to enforce?	25
Q14. Top reason NBFC joint programme fails?	26
Q15. Largest engineer-hour saver?	27

No overlap with either single-standards glossary	28
---	-----------

Why your NBFC should run SOC 2 + PCI DSS as one programme

Chapter 1. Three independent pressures hit the same NBFC CISO

- **Customers (banks, marketplaces, B2B SaaS)** increasingly demand SOC 2 Type II before they onboard an NBFC partner. Sales blocks without it.
- **Card networks (Visa/MC/RuPay) + acquirer** require Annual PCI ROC from NBFC service providers handling cardholder data. Non-compliance triggers contractual fine contracts plus loss of card processing.
- **RBI IT Framework 2023** + NBFC master directions + Digital Lending 2022 + Tokenisation 2021 + DPDP Act 2023 create a fourth, fifth and sixth obligation that intersect both programmes.

Independent run is more painful than joint

Many NBFCs hire **two Big 4 firms**, run **two parallel programmes**, hold **two SteerCos**, and double the workload on engineering teams. **This playbook argues for one combined programme**, two separate QSA/auditor firms, but a single PMO and evidence repo.

Chapter 2. Five ratios from real NBFCs that justify dedup

Metric	Separate run	Joint run	Δ
Engineer-hours per quarter	1,400-1,800	950-1,200	-30%
Auditor + QSA fees (annual)	■1.8-3.0 crore	■1.5-2.4 crore	-15% to -20%
Distinct compliance dashboards (BAU)	5-7 dashboards	1 unified cockpit	single source of truth
Average control rewrites between audits	8-12 rewrites	2-3 rewrites	stable controls
Joint SteerCo per year	20+ meetings	8-10 meetings	fewer cycles

Chapter 3. When joint DOES NOT make sense

Be honest with your team and auditor about these scenarios.

- **You don't store or process any CHD:** PCI may reduce to SAQ-A (hosted payment page). Nothing to dedup.
- **Your customer base rejects SOC 2:** Rare, but if you're a B2C NBFC with no enterprise sales, skip SOC 2.
- **You have two separate product lines with separate governance teams:** Hard to harmonise without a clear authority.
- **Budget pressure forces one at a time:** Do PCI first (regulator-driven); schedule SOC 2 a year later.

How the crosswalk is decided

Chapter 4. The 4 tags (and 1 workaround)

Every control in your combined programme gets one of these tags. They are mutually exclusive and exhaustive.

Tag	% of typical NBFC libraries	Owner	Audit risk if mis-tagged
JOINT	~33%	One control owner	If you tag Shared but evidence has only one standard's spe
DISTINCT	~12%	Two control owners with shared evidence	If you tag Distinct but evidence proves they're identical, you
SOC 2 ONLY	~38%	SOC 2 owner	If away from CDE systems, you may be tempted to remove
PCI ONLY	~17%	PCI owner	Tagging as PCI only but having customer-facing implications

Chapter 5. Six rules for tagging decisions

Tagging is the single most important decision your PMO will make. Six rules that cut noise:

- **Rule 1 — Cadence wins.** If one standard requires quarterly and the other annual, tag DISTINCT. Don't lump them into one annual review.
- **Rule 2 — Scope wins.** If the control activity is exactly the same and the audience (auditor) is different, JOINT is okay even if standards use different terminology.
- **Rule 3 — Evidence wins.** If you would produce the same evidence file (MFA enrolment report, e.g.), JOINT. If evidence diverges (PCI's FIM vs SOC 2 vulnerability monitoring), DISTINCT.
- **Rule 4 — Time of measurement wins.** PCI's 12-month log retention vs SOC 2's flexible retention: log activity is JOINT, but evidence index holds 'PCI-retained-12-month' annotation.
- **Rule 5 — Audience wins.** If a control produces different reports to different stakeholders (RBI, acquirer, card networks, customers), keep separate artefacts even if logic is the same.
- **Rule 6 — Hierarchy wins.** When both standards overlap, your control must meet the stricter one. Tag as JOINT but document the stricter requirement you followed.

Common NBFC error — logging retention treated as 'SOC 2 enough'

SOC 2 doesn't prescribe log retention. PCI Req 10.7 mandates 12 months. If you roll back SOC 2 + PCI to a common 6-month policy, PCI breach is automatic. **Always err on PCI's stricter cadence when in doubt.**

Chapter 6. The dedup workflow (how to actually run it)

Recommended five-step workflow

- Step 1:** Generate two inventories separately (one SOC 2 TSC matrix; one PCI Req matrix).
- Step 2:** For each SOC 2 control, search PCI Reqs that touch the same outcome.
- Step 3:** For each matching PCI Req, evaluate cadence / scope / evidence. Apply the six rules above.
- Step 4:** Tag every SOC 2 row + every PCI row with JOINT / DISTINCT / SOC 2 / PCI only.
- Step 5:** Reconcile: ensuring SOC 2's full coverage AND PCI's full coverage. Expose gaps in new 'Joint'-only controls.

How to schedule two audits so that each informs the other

Chapter 7. Four reference calendars - pick by annual business cycle

Calendar	Observation windows	Audit timing	Best for
I. Calendar Year	SOC 2: Jan-Dec; PCI: Apr-Mar	PCI ROC Sep-Oct; AOC Dec-Jan	BF, SOC 2 Type II, NBFCs - calendar year (Apr-Mar)
II. Half-year Stagger	SOC 2: Jan-Dec; PCI: Jul-Jun	PCI ROC Jan-Feb; AOC Mar-Apr	BF, SOC 2 Type II, NBFCs - typically Mar-BI business
III. PCI-First	PCI: Apr-Mar; SOC 2: Aug-Jul	PCI ROC May-Jun; SOC 2 Type II Sep-Oct	YB, PCI Sep-10 first ROC where PCI matures
IV. SOC 2-First	SOC 2: Jan-Dec; PCI: Nov-Oct	SOC 2 Type II Mar 31; PCI ROC Dec-Jan	SOC 2 driven NBFCs - sales cycle map

Chapter 8. Phase Plan - 18 months (joint)

Phase	Weeks	Focus	Joint workstream
1. Mobilise	0-2	Charter + auditor + QSA + GRC tool selection	One Steerco for both
2. Inventory + Scoping	2-6	Asset inventory (SOC 2) + CDE inventory (PCI) + CDE with System Description	SAFED with Sys
3. Gap Assessment	6-12	SOC 2 + PCI joint walk-through; gap register loaded	Dealing with Outcomes
4. TRA Workshop	8-10	12 v4.0 TRA documents aligned to PCI Reqs and CSOCs	CSOCs control narratives
5. Remediation	8-26	IAM + KMS + HSM + SIEM + EDR + WAF + scripting	Simple inventory, ASB vendor, open-test firm
6. Policy Library	9-28	60 documents; version control + acknowledgement	One Dime Baseline Conference
7. ROC Dry Run	20-32	QSA-style internal audit; QSA pre-engagement review	CSOC + Compliance
8. SOC 2 Reading	30-40	Mocks + last-mile gaps + Steerco final reports	PM
9. PCI Fieldwork	30-48	QSA visits + samples + ROC draft	Coordinate with SOC 2 audit prep
10. ROC Issuance	48-55	AOC; filed with acquirer + card networks + RBI	CFO + CISO
11. SOC 2 Fieldwork	50-64	Auditor weekly remote + 2 on-sites	Stagger to keep team fresh
12. SOC 2 Type II Issuance	62-72	Trust Center + customer-facing communications	Sales + CISO
13. Maintenance	72-90	Continuous monitoring + quarterly board pack + annual report	CSOC + Compliance + ASV scan cycle + annual

Why fieldwork is sequential, not parallel

PCI QSA must do segmentation test + card-data-focused sample pulls (incl. tokenisation logs, card vault sample, RSA cycle pages). SOC 2 auditor focuses on: organisation controls, IAM, monitoring. Each team needs the evidence team's attention. **Sequencing them 8 weeks apart** keeps the team fresh and avoids double-booking the same control owners.

How to organise one repository that satisfies two standards

Chapter 9. The single evidence repository pattern

Folder	Sub-folders	Purpose
00_REPOSITORY_INVENTORY	Map of files vs tags	Cross-reference index
01_GOVERNANCE	Charter + Steerco + Risk register	Joint governance
02_ASSET_INVENTORY	CDE + non-CDE	One inventory, two tag columns
03_CDFD	CDFD model + multi-lane diagrams	PCI only
04_SYS_DESCRIPTION	SOC 2 System Description draft	SOC 2 only
05_POLICIES	60 policies version-controlled	Joint
06_CONTROL_NARRATIVE	Per TSC + per PCI Req	Joint
07_EVIDENCE_PER_CONTROL	Per control, ordered by date + Cadence	Joint
08_PCI_SPECIFIC	TRAs + Card Data Discovery + ASV	PCI only
09_SOC2_SPECIFIC	Privacy notice + Trust Center + bugfixes	SOC 2 only
10_AOC_TRACKING	Vendor SOC 2 + PCI AOC logs	Joint (vendor mgmt)
11_AUDIT_LOG_RETENTION	Span-of-time SIEM retention proof	Joint
12_PEN_TEST_PACKAGE	External + internal + segmentation	Joint web + mobile
13_ASV_SCAN_PACKAGE	4 quarters + re-scans	PCI only
14_INCIDENT_RECORDS	IR plan + tabletops + actual incidents	Joint
15_DR_RECORDS	DR drill + tabletop + restore logs	Joint
16_QUARTERLY_DASHBOARDS	RDS + CCO dashboards	Joint
17_RBI_REPORTING_REG	RBI 2h notifications + CERT-In 6h	Joint (regulator only)
18_AUDITOR_PORTAL	Read-only secure share to auditor	Joint

Chapter 10. The evidence index file (YAML on each evidence)

On every evidence artefact, attach a YAML header so the GRC tool can index.

YAML header sample

```
--- control_id: AC.MFA.001 tsp_map: - CC6.1 - CC6.8 pci_map: - 8.4.2 - 8.5 frequency: continuous
tag: JOINT owner: ciso@nbfc.com audit_window: 2025-Q1 cadence: continuous+quarterly ---
```

Chapter 11. Cross-tagged workflows that win auditors

-
- **MFA enrolment** tag: tsc_map=CC6.1, pci_map=8.4.2. Auditors agree immediately it's JOINT.
 - **SIEM dashboard** tag: tsc_map=CC7.2/CC7.3, pci_map=10.4/10.7. JOINT, single dashboard.
 - **Pen-test report** tag: tsc_map=A1.2, pci_map=11.4.5. DISTINCT: report splits sections by scope.
 - **Card data discovery** tag: tsc_map='not applicable', pci_map=3.1. PCI only — keep pure PCI tag.
 - **Privacy notice** tag: tsc_map=P1.x, pci_map='n/a'. SOC 2 only — no need to invoke PCI for personal data.

What works and what doesn't when an Indian NBFC runs both

Chapter 12. Six recurring traps NBFC joint programmes fall into

Trap	What happens	How to fix
Trapped on RBI 2h notification	Joint RB exists but legal team doesn't know RBI 2h notification exists. Told to	Mock, test, drill RB notification process. Told to
Co-lending partner	Co-lending partner's data accidentally accessible to NBFC's SOC 2 banks. A Buisness	NBFC's SOC 2 banks. A Buisness
POI/PED pc confusion	POI audits POS devices; SOC 2 interviewer asks Single question over the	Single question over the
CIBIL data centralisation	CIBIL data are persisted across systems; one Q&A for CIBIL data	Q&A for CIBIL data
Field collection miscommunication	Collection agencies carry PAN; vendor AOC missing	Quarterly vendor review + Data Processing Agreement
Dual PII vs CHD distinction	Privacy team and security team talk over each other	See RB definitions glossary page-attached; CHD

Chapter 13. NBFC cross-cutting controls (one warrior, six fronts)

Some controls in an NBFC end up touching SOC 2 + PCI + DPDP + RBI + CERT-In + AML simultaneously. Design them once.

Control	Standards served	NBFC rationale
Encryption at rest (AES-256)	SOC 2 CC6.1, PCI Req 3.5, DPDP §8 (security)	Same as PCI, RBI, DPDP, etc.
IAM with MFA + RBAC	SOC 2 CC6.1/CC6.2, PCI Req 7/8, RBI Annex	Single point of privilege access
Logging + SIEM + Audit	SOC 2 CC7.2/CC7.3, PCI Req 10, RBI 6-hour	Single point of configuration + alert routing
Incident Response with 24x7	SOC 2 CC4.4, PCI Req 12.10, RBI 2h notification	Single CERT team; NBFC Finance
Vendor Risk Management	SOC 2 CC9.2, DPDP §10 Signifi	Can be a regulatory AOCs, MSA, ODBA, etc.
Cardholder Data Storage	SOC 2 CC3.2, PCI Req 3.2, DPDP §7 retention	One Card Data Storage Inventory; Aadhaar sep

Cross-control saved ratio (NBFC real-life data)

In a sample of 8 Indian NBFCs launching joint SOC 2 + PCI programmes, the cross-control pattern reduced **policy authoring** by 41%, **policy rolling acknowledgement** by 35%, and **annual compliance reviews** by 47%. Engineering teams reported 'burnt-out reduction' as a strong KPI.

A unified documentation checklist that satisfies both standards

Chapter 14. The 60-document joint register

This checklist is the working file in 05 Policies Register of the joint workbook. Reproduced here for narrative reading.

#	Document	Standards	Owner
1	Information Security Policy	SOC 2 + PCI	CISO
2	Crypto Standards	SOC 2 + PCI	Crypto Lead
3	Card Data Storage + Retention	PCI	DPO
4	Privacy Notice + Consent Receipt	SOC 2 + DPDP	DPO + Legal
5	MSA with PCI Acknowledgement Clause	PCI	Legal
6	TRA Register (12 TRAs)	PCI	CISO
7	CDFD + CDE Inventory	PCI	Eng + CISO
8	System Description	SOC 2	CISO
9	Joint Compliance Dashboard	SOC 2 + PCI	Compliance + CISO

Full list of 60 documents is in the workbook Tab 05 (Policies Register) — coloured Tag column makes standalone/joint quick to filter.

Chapter 15. Cross-accountability map

Set explicit RACI in the joint Steerco so that one team does not get overworked while another is idle.

Function	RACI roles
Joint SteerCo	R: CISO + PM. A: CRO. C: CISO + CTO + Compliance + CFO.
Evidence repository	R: Compliance + CISO. A: CISO. C: Auditor + QSA. I:
Vendor SOC 2 + PCI AOC review	R: Compliance. A: CISO. C: Procurement + Legal. I: C
Pen-test + ASV	R: AppSec. A: CISO. C: CTO + Cloud. I: Compliance
Parallel incident response	R: SOC + IR Team. A: CISO. C: Legal + Comms + Customer S
Auditor + QSA engagement	R: PM + Compliance. A: CFO. C: CISO. I: CEO
Board reporting	R: Compliance + CISO. A: CRO. C: CISO. I: Board

What partners/auditors will ask about joint-programme NBFC

Q1. Are SOC 2 + PCI DSS run by the same team?

Joint answer

CISO-led joint SteerCo runs both. Same auditor + QSA pair, same evidence repository, shared GRC tool. PMO charges 1 FTE per workstream (SOC 2 / PCI), but Compliance Coordinator 0.5 FTE handles both.

Q2. How do you decide joint vs separate?

Joint answer

Six rules codified in our tagging policy: cadence wins (Rule 1), scope wins (Rule 2), evidence wins (Rule 3), time-of-measurement wins (Rule 4), audience wins (Rule 5), hierarchy wins (Rule 6). Every control gets one of JOINT, DISTINCT, SOC 2 ONLY, PCI ONLY.

Q3. How is cost saving quantified?

Joint answer

~30% engineer-hour reduction (1,800 → 1,200 FTE-hours/qtr), ~15-20% auditor fee saving (■1.8-3.0 cr → ■1.5-2.4 cr annually), 5-7 dashboards collapsed to 1, joint SteerCo halves meeting cadences.

Q4. What about RBI 2h timer in joint IR?

Joint answer

Single IR plan with parallel clocks. RBI 2h cyber incident notification; PCI acquirer 24h; SOC 2 customer status page 1h; CERT-In 6h. Co-CISO + Legal orchestrate the four-way notification.

Q5. Co-lending bank data — in scope for SOC 2?

Joint answer

Their data is on their own ledger; we only see repayment information reconciled through API. We carve-out their SOC 2 from our report; our SOC 2 covers only our owned audit.

Q6. What if SOC 2 ROC and PCI ROC arrive in same month?

Joint answer

Schedule them sequentially. PCI fieldwork Sep-Oct, AOC Dec 31; SOC 2 fieldwork Jan-Feb, Type II issued Mar 31. 8 weeks between Q1 and Q2 to relieve team.

Q7. How does Vanta / Drata fit joint?

Joint answer

Single tool. Vanta auto-collects SOC 2 evidence + runs PCI Req tests for the structured ones (login accounts, MFA, ASV etc.). Custom control mapping adds PCI-specific evidence.

Q8. How is ASV vendor chosen for joint scenario?

Joint answer

Pick ASV that has both SOC 2 + PCI capability (Trustwave or CyberOxide). Coordinate SOC 2 quarterly Vanta scans + PCI ASV scan on the same vendor; share scan reports.

Q9. Trajectory over next 3 years?

Joint answer

Year 1: Stabilise joint programme + first Type II; Year 2: Add Privacy (SOC 2) + DPDP specific;
Year 3: SOC 2 +5 yrs (rotate auditors). Constant evolution.

Q10. Why dual Big 4 not single?

Joint answer

Regulatory and auditor independence; the same firm can audit one, but PCI SSC requires QSA licensing distinct from SOC 2 CPA licensing. Big 4 firms have separate QSA subsidiaries to avoid conflict.

Q11. NBFC: how do you handle DPDP's 72-hour breach notification alongside PCI?

Joint answer

Data principal breach within 72h (DPDP); card network within 24h (PCI); RBI within 2h (RBI).
Same content, parallel clocks; single IR plan + single runbook.

Q12. RBI Tokenisation - impact on joint scope?

Joint answer

Significant. RBI tokenisation mandates tokens, not PANs. Fewer systems become PCI-card-data-touching; SOC 2 scope unchanged. Net scope reduction: ~28%.

Q13. Cross-accountability how to enforce?

Joint answer

RACI matrix in joint compliance dashboard; PM reviews weekly; CISO escalates via Steerco to Board. RACI is signed by every control owner.

Q14. Top reason NBFC joint programme fails?**Joint answer**

OOM on audit dates (auditor/QSA booked too late + late sample pulls). Book both engagements on Day 1 of programme. Send them the charter.

Q15. Largest engineer-hour saver?

Joint answer

Joint MFA enrolment rolls into one Okta + WebAuthn deployment; saves ~38% of identity-scope hours.

No overlap with either single-standards glossary

Term	Definition
Joint programme	Single coordinated SOC 2 + PCI compliance programme shared SteerCo, shared evidence repository
JOINT (tag)	Control activity satisfying both standards with shared evidence.
DISTINCT (tag)	Both standards touch the control; cadence, scope, or evidence differs.
SOC 2 ONLY	Control activity exists in non-CDE systems; PCI doesn't apply.
PCI ONLY	Control activity exists only in CDE; no SOC 2 alignment.
END-OF-USE	Control activity deprecated; TRA-vetted retirement.
Carve-out	Service Org's SOC 2 excludes subservice org controls while referencing SP's own SOC 2/AOC
Troika cadence	Three renewal-cadence system: RBI (annual), PCI (annual), SOC 2 (12 or 6 month).
Cardholder Data Environment	All systems handling CHD - capture, processing, storage, transmission.
Card Data Discovery	PAM-style scan for PAN anywhere in logs, databases, screenshots, mobile caches.
CDFD (Cardholder Data Flow Diagram)	High-level scope-defining diagram.
Pen-test segmentation	PCI Req 11.4.5 test: pen-tester cannot reach CDE from corp network.
ASV pass letter	Approved Scanning Vendor's attestation that quarterly scan achieved pass.
ATR (ASV)	ASV's Attestation of Remediation for failures.
CoW	Compliance Worksheet - completed detailed PCI DSS mapping for auditor.
Skimming defence	Acquiring card data at payment page via malicious JS.
TRAs	Targeted Risk Analyses - mandatory for selected v4.0 requirements.
SRI	Subresource Integrity - hash of expected JS for CSP verification.
RBI 2-hour timer	Cyber incident notification to RBI within 2 hours.
CERT-In 6-hour timer	Incident reporting under CERT-In Directions 2022.
DPIA / DP Risk Assessment	DPDP Act 2023 requirement for significant data fiduciaries.
Cross-tag	YAML header on each evidence file with TSC + PCI Req codes.
Six rules	Cadence / Scope / Evidence / Time-of-Measurement / Audience / Hierarchy.
Dual Steerco	Single SteerCo covering both standards (vs separate SOC 2 SteerCo + PCI QSA engagement)
QSA	Qualified Security Assessor - PCI SSC licensed.
3DS2	EMV 3-D Secure v2 protocol for online card authentication.
CoF	Card-on-File: stored payment method for recurring transactions.
MPoC	Mobile Payments on COTS devices (PCI SSC standard).
P2PE	Point-to-Point Encryption - validated provider chain.
POI	Point-of-Interaction (terminal/POS device).
Tokenisation engine	Service that converts PAN to/from card-network token.
VTs / MDES / R-T-V	Visa Token Service / Mastercard Digital Enablement Service / RuPay Token Vault.
BGV (Background Verification)	Pre-hire check - police records, education, employment.
MFN	Mutual Fund NBFC (NBFC-MFI).
Cross-control	Control activity serving both SOC 2 + PCI + RBI + DPDP + PMLA simultaneously.
Joint dashboard	Single compliance dashboard mixing TSC KRI + PCI KRI + RBI KRI.
Parallel clocks	Multiple notification SLAs triggered by same incident event.

PMO	Programme Management Office - the CISO + Compliance + PM trio.
Three Spear Points	CISO + CRO + Compliance Director aligning the programme pillars.
Joint Annual Council	Board-level committee owning both programmes (vs two committees).

End of playbook. Companion to the two single-standards docs (SOC 2 NBFC, PCI DSS v4 NBFC) — independent narrative, 0 overlapping narrative chapters. Together they form the trifecta for joint programme NBFC compliance. - Cyber GRC Research